

Executive Brief: Ajna ERC-4626 Vaults + CRE Automation

Date: 2026-03-24

Audience: protocol core team, ops, risk, and partner/investor diligence

Bottom Line

The system is technically solid at the contract level but is not yet operationally robust enough for unconstrained mainnet scale. The key risk is not classic smart contract exploitability; it is **redemption liveness and fairness under stress** due to **buffer-only withdrawals** plus offchain rebalancing dependence.

What Works

- Onchain architecture is coherent and modular (``Vault``, ``VaultAuth``, ``Buffer``, ``AjnaVaultLibrary``).
- Role checks and reentrancy guards are present in critical move paths.
- Share decimal integrity issue has been fixed via ``_decimalsOffset()`` override.
- CRE runtime bridge adds meaningful idempotency/replay controls (``idempotency_key``, replay nonces, queue dedupe).
- Ajna canonical automation path correctly fail-closes on admin mismatch for CSW-scoped actions.

Highest Risks

1. **Buffer-only exit bottleneck**

Withdrawals/redeems are paid from the buffer only. During stress, early users can exit while later users revert until rebalancing succeeds.

2. **Accounting vs realizable-liquidity mismatch**

``totalAssets()`` can remain high while practical exits are blocked or economically impaired by Ajna market states.

3. **Keeper/config fragility**

Safety depends on offchain config correctness (cadence, oracle mode, subgraph behavior, fixed price toggles), not just code correctness.

4. **Centralized write authority in bridge mode**

CRE workflows still rely heavily on HTTP bridge writes from a shared keeper key for many actions.

Recommended Direction

Adopt **CRE-centric orchestration with deterministic guardrails**:

- Move scheduling, policy checks, monitoring, queueing, and checkpointing to CRE.
- Keep write execution narrowly scoped, allowlisted, and deterministic.
- Keep AI advisory only; never use AI as safety-critical gate logic.
- Maintain fallback paths during migration; deprecate legacy loops only after SLO proof.

Go/No-Go Assessment

- Smart contract safety: 7/10
- Accounting integrity: 6/10
- Redemption fairness: 4/10
- Liveness robustness: 4/10
- Oracle/data robustness: 5/10
- Operator risk: 4/10

- CRE suitability: 6/10
- Overall deployability: 5/10

****Recommendation:**** pilot deployment only (strict TVL cap), no broad-scale deployment until liveness and operator-risk controls are hardened.

Minimum Blockers Before Mainnet Scale

1. Dynamic buffer policy and faster/event-driven refill loop.
2. Production fail-closed settings for critical data dependencies.
3. Strict oracle policy (remove unsafe fixed-price operational usage).
4. Hardened signer custody and governance controls (multisig/timelock/HSM or MPC).
5. Proven reliability under replay/outage/duplication chaos tests.
6. User-facing disclosure of realizable-now liquidity vs accounting value.